WASF204: THEORY, COMPLIANCE, AND LAB-BASED EVALUATION

Student Name: Leslie Nii Adjetey
Student ID: 2025/CFP/6957
Course Name: WASF204: Theory, Compliance, and Lab-Based Evaluation
Date of Submission: 20/07/2025
Instructor: MR. Abubakar Nasiru Salihu

Assignment Objective

The objective of this assignment is to assess students' understanding of core cloud security principles, including the Shared Responsibility Model, threat modelling (STRIDE and DREAD), data protection techniques, and compliance with cloud security standards. Through both theoretical and hands-on tasks, students will demonstrate their ability to analyse security responsibilities, apply encryption for data protection, and align practices with regulatory requirements in a cloud environment.

Description

This lab introduces students to encryption and compliance in cloud security. Students will encrypt and decrypt a file using OpenSSL to demonstrate data protection at rest and set up a Python HTTPS server to show encryption in transit. The lab also highlights how these practices support compliance with standards like GDPR, HIPAA, and PCI-DSS.

Section A (1–2 pages)

1. Answer the following questions**:**

- In your own words, explain what the Shared Responsibility Model means and why it is important for cloud security.

  The shared responsibility model is a security framework that defines the division of responsibilities between a cloud service provider and its customers. The model is important for cloud security because it lays out the concept of responsibilities for both parties and ensures that there are active contributions on both sides towards the security of the cloud service.

- For each cloud model **(**IaaS, PaaS, SaaS**),** give one real world example of a security responsibility that falls on the user side and explain what could go wrong if it's neglected.

  IaaS: Users are responsible for the configuration of network security groups. If users fail to properly configure security groups, unauthorized users could gain

access to the system which could lead to data breaches, malware infections, or ransomware attacks.

PaaS: Users are responsible for securing application-level authentication and authorization. If users fail to do so, threat actors could have unauthorized access to the application using stolen credentials or they could bypass the login page completely.

SaaS: Users are responsible for managing user access and permissions. If users fail to properly manage access such as not revoking permissions for former employees or granting excessive privileges, attackers could exploit these accounts to access sensitive data.

- A company is using a SaaS email service (like Gmail or Microsoft 365). List two security responsibilities that remain with the company (not the provider) and describe how they should handle them.

  User access and identity management: The company handles this responsibility by managing user accounts, defining granular account permissions, and enforcing multi-factor authentication (MFA) across all users. This is achieved by configuring MFA through the platform's admin console (e.g., Azure Active Directory for Microsoft 365 or Google Workspace Admin Console), implementing strong password policies with complexity requirements, and conducting regular audits to identify and deactivate dormant or ex-employee accounts. Additionally, the company should leverage single sign-on (SSO) for streamlined access control and apply conditional access policies to restrict logins based on factors like device compliance, geographic location, or detected risk levels. For example, setting up Microsoft 365's Azure AD to block logins from untrusted IP addresses enhances security by preventing unauthorized access attempts.

  Data protection and encryption: The company handles this responsibility by securing sensitive email data with encryption and preventing unauthorized sharing. This is achieved by enabling provider tools like Gmail's confidential mode or Microsoft 365's message encryption, ensuring Transport Layer Security (TLS) for email transmission, and configuring Data Loss Prevention (DLP) policies to block sensitive information, such as credit card numbers, from being sent. Employee training on secure email practices further mitigates risks.

Section B (1 pages)

Threat Modelling with STRIDE and DREAD

System/Component: (User Login Page of an Online Banking Web Application) based on the scenario complete the table by completing the identified threat.

2. **STRIDE Threats:**

Threat Category	**Identified Threat**
Spoofing	Phishing attacks using fake login pages that mimic the legitimate banking website to steal user credentials
Tampering	Man-in-the-middle attacks intercepting and modifying login requests to capture or alter authentication data
Repudiation	Users denying they performed login activities due to insufficient audit logging of authentication attempts
Information Disclosure	Exposure of sensitive authentication data (usernames, passwords, session tokens) through insecure transmission or storage
Denial of Service	Brute force attacks or credential stuffing overwhelming the login system, preventing legitimate users from accessing their accounts
Elevation of Privilege	Session hijacking or privilege escalation allowing attackers to gain unauthorized access to customer accounts or administrative functions

3. **DREAD: write the analysis of the selected threat and score it**

Factor	**Score (1– 10)**	**Justification**
Damage Potential	9	High impact - compromised banking credentials can lead to financial theft, identity theft, and significant financial losses for customers. Regulatory penalties and reputational damage for the bank.
Reproducibility	7	Moderately reproducible - requires specific conditions like unencrypted transmission, weak encryption, or access to storage systems, but these vulnerabilities can be consistently exploited once identified.
Exploitability	6	Moderate difficulty - requires technical knowledge of network protocols or system access, but tools and techniques are readily available. May require specific positioning (network access) or system vulnerabilities.

Affected Users	9	Very high impact - potentially affects all users of the banking system. Each compromised account represents significant financial and personal risk to customers.
Discoverability	5	Moderate discoverability - vulnerability may not be immediately obvious but can be detected through network analysis, security testing, or system audits. Some technical expertise required.

Total Score: ___36___ / 50
Priority Level: High

Section C: Short Answer Questions (1–2 pages)

1. Define the term data lifecycle and list all its stages.

Data Lifecycle is the sequence of stages that data goes through from its initial creation or collection until its final disposal or destruction. It encompasses all activities and processes that occur throughout the existence of data within an organization.

Stages of Data Lifecycle:

- **Creation/Collection**: Data is generated, captured, or acquired from various sources
- **Storage**: Data is saved in databases, file systems, or cloud storage platforms
- **Processing**: Data is analysed, transformed, or manipulated to extract value
- **Sharing/Distribution**: Data is transmitted or made available to authorized users or systems
- **Archival**: Data is moved to long-term storage for compliance or historical purposes
- **Retention**: Data is maintained according to legal, regulatory, or business requirements
- **Disposal/Destruction**: Data is securely deleted or destroyed when no longer needed

2. Explain the difference between data sovereignty and data residency.

Data sovereignty is about legal control and compliance with the laws of the country where data is located, while data residency is about the physical location of data storage or processing, which may or may not align with legal obligations.

3. Why is data classification important in a cloud environment?

Data classification is critical in a cloud environment because it enables organizations to identify, categorize, and prioritize data based on its sensitivity,

value, and regulatory requirements. By classifying data, companies can apply appropriate security controls, such as encryption or access restrictions, to protect sensitive information and ensure compliance with laws like GDPR or HIPAA

4. Give five real world examples of each of the following classification levels:

A. Public

Company website content and marketing materials

Published financial statements and annual reports

Press releases and public announcements

Product catalogues and pricing information

Job postings and recruitment materials

B. Internal

Employee handbook and internal policies

Organizational charts and department structures

Internal meeting minutes (non-sensitive)

Training materials and procedures

Budget summaries and departmental metrics

C. Confidential

Customer contact information and purchase history

Vendor contracts and pricing negotiations

Product development roadmaps and strategies

Employee performance reviews and salary information

Competitive analysis and market research data

D. Highly sensitive

Social Security numbers and personal identification data

Medical records and health information (PHI)

Credit card numbers and payment information (PCI data)

Trade secrets and proprietary algorithms

Legal documents and regulatory investigation materials

Section D: (1–2 pages)

Briefly explain why cloud compliance is more challenging than traditional IT compliance.

Cloud compliance presents unique challenges compared to traditional IT compliance due to several factors:

Shared Responsibility Model: In cloud environments, security and compliance responsibilities are divided between the cloud service provider and the customer, creating complexity in understanding who is responsible for what aspects of compliance.

Multi-tenancy: Cloud resources are often shared among multiple customers, making it difficult to ensure isolation and control over data and applications.

Dynamic Infrastructure: Cloud resources can be provisioned, modified, and deprovisioned rapidly, making it challenging to maintain consistent compliance postures and audit trails.

Geographic Distribution: Data may be stored and processed across multiple jurisdictions simultaneously, creating compliance complexity with varying international laws and regulations.

Limited Visibility: Organizations have reduced visibility into the underlying infrastructure, making it harder to demonstrate compliance and conduct thorough audits.
Vendor Management: Organizations must rely on third-party cloud providers and ensure they meet compliance requirements, adding another layer of complexity to compliance management.

Choose two compliance standards (e.g., GDPR and HIPAA) and compare them using:

- Who they apply to
- The type of data they protect
- A real-world consequence of non-compliance

General Data Protection Regulation (GDPR)

- **Who it applies to**: Organizations that process personal data of EU residents, regardless of where the organization is located
- **Type of data protected**: Personal data of EU individuals, including names, addresses, IP addresses, and any information that can identify a person
- **Real-world consequence**: British Airways was fined £20 million in 2020 for a data breach affecting 400,000 customers due to inadequate security measures

Health Insurance Portability and Accountability Act (HIPAA)

- **Who it applies to**: Healthcare providers, health plans, healthcare clearinghouses, and their business associates in the United States
- **Type of data protected**: Protected Health Information (PHI), including medical records, health insurance information, and any health-related data that can identify an individual
- **Real-world consequence**: Anthem Inc. paid $16 million in 2018 for a breach affecting 79 million individuals due to insufficient risk analysis and inadequate access controls

A company stores customer data on multiple cloud platforms (AWS, Azure, GCP). List 3 steps it must take to remain compliant with international privacy laws.

For a company storing customer data across AWS, Azure, and GCP, three essential compliance steps are:

Data Mapping and Classification: Conduct comprehensive data mapping across all three cloud platforms to identify what personal data is stored where, classify it according to sensitivity levels, and document data flows between platforms and regions.

Implement Consistent Privacy Controls: Deploy standardized privacy and security

controls across all platforms, including encryption at rest and in transit, access controls, monitoring systems, and data loss prevention tools to ensure consistent protection regardless of the cloud provider.

Establish Cross-Platform Governance: Create unified privacy policies, procedures, and governance frameworks that address data subject rights (like GDPR's right to deletion), breach notification requirements, and vendor management across all three cloud environments.

Why is it important to understand data breach notification laws? What could happen if a company delays reporting a breach?

Understanding data breach notification laws is critical because they establish legal requirements for how and when organizations must report security incidents to authorities and affected individuals.

Key Importance:

- **Legal Compliance**: Failure to comply with notification requirements can result in significant fines and penalties
- **Stakeholder Trust**: Timely notification helps maintain customer and partner trust during crisis situations
- **Regulatory Relationships**: Proper notification demonstrates good faith compliance efforts to regulators

Consequences of Delayed Reporting:

- **Increased Penalties**: Regulators often impose higher fines for late notification, as seen with GDPR's requirement to notify within 72 hours
- **Reputational Damage**: Delayed disclosure can appear as a cover-up attempt, severely damaging public trust and brand reputation
- **Legal Liability**: Late notification may increase exposure to class-action lawsuits and individual claims from affected parties
- **Regulatory Scrutiny**: Organizations may face increased oversight, audits, and monitoring from regulatory bodies

- **Business Impact**: Loss of customer confidence can lead to decreased revenue, partnership dissolution, and competitive disadvantage

Section E: Lab Completion

Instructions: Attempt all questions. Provide command line steps, code snippets, and brief explanations where required with screenshots.

1: Encryption of Data at Rest Using OpenSSL

You are required to demonstrate how encryption can be applied to protect data at rest using OpenSSL.

a. Create a text file named secret.txt and write the following content inside: "Confidential data:
Access is restricted to authorized users only."

```
┌──(bones㉿vbox)-[~/Desktop]
└─$ touch secret.txt

┌──(bones㉿vbox)-[~/Desktop]
└─$ ls
2025-05-11.burp          2025-07-12.burp.backup     auth_log.txt            ctf2.txt   dub.txt      install.ps1             Lab2_HTMLInjection   license.txt         Nasarawastate.burp.backup   pension_clean.txt   rce_test.txt
2025-05-11.burp.backup   2025-07-12-Nasa-CTF.burp   Burpsuite-Professional  ctf.txt    hash.txt     'Lab 1 screenshots'     Labs                 loader              os                          pension.txt         secret.txt
2025-07-12.burp          access_log.txt             ctf1.txt                dic.txt    history.txt  'Lab 1 screenshots.zip'  license1.txt         Nasarawastate.burp  output.txt                  ping.sh             sshlog.txt
```

b. Use OpenSSL to encrypt the file using the AES-256-CBC algorithm and save the output as secret.enc.

```
┌──(bones㉿vbox)-[~/Desktop]
└─$ openssl enc -aes-256-cbc -salt -in secret.txt -out secret.enc
enter AES-256-CBC encryption password:
Verifying - enter AES-256-CBC encryption password:
*** WARNING : deprecated key derivation used.
Using -iter or -pbkdf2 would be better.

┌──(bones㉿vbox)-[~/Desktop]
└─$ ls
2025-05-11.burp          2025-07-12.burp.backup     auth_log.txt            ctf2.txt   dub.txt      install.ps1             Lab2_HTMLInjection   license.txt         Nasarawastate.burp.backup   pension_clean.txt   rce_test.txt   sshlog.txt
2025-05-11.burp.backup   2025-07-12-Nasa-CTF.burp   Burpsuite-Professional  ctf.txt    hash.txt     'Lab 1 screenshots'     Labs                 loader              os                          pension.txt         secret.enc
2025-07-12.burp          access_log.txt             ctf1.txt                dic.txt    history.txt  'Lab 1 screenshots.zip'  license1.txt         Nasarawastate.burp  output.txt                  ping.sh             secret.txt
```

c. Decrypt the encrypted file and save the result as secret_decrypted.txt.

```
┌──(bones㉿vbox)-[~/Desktop]
└─$ cat secret.enc
Salted__◆đ◆tO0◆◆◆4p◆◆jwU◆◆Aχ◆◆U◆◆◆2◆◆◆◆◆◆;◆◆q'◆kЬ◆◆L◆◆◆◆◆
                                                          4M6◆◆=A◆ D◆ (◆YC◆◆◆◆

┌──(bones㉿vbox)-[~/Desktop]
└─$ openssl enc -aes-256-cbc -d -in secret.enc -out secret_decrypted.txt
enter AES-256-CBC decryption password:
*** WARNING : deprecated key derivation used.
Using -iter or -pbkdf2 would be better.

┌──(bones㉿vbox)-[~/Desktop]
└─$ cat secret_decrypted.txt


Confidential data:
Access is restricted to authorized users only.
```

2: Encryption of Data in Transit Using HTTPS Server

You are required to demonstrate encryption of data in transit using HTTPS.

a. Generate a self signed SSL certificate and private key using OpenSSL, valid for 365 days. Save them as cert.pem and key.pem.

```
┌──(bones㉿vbox)-[~/Desktop]
└─$ openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365 -nodes
.+.......+..+..............+............+...+...+..+...+......+.+..............+.+..+.+.....+....+...........+.+....
+++++++*....+..........+......+.....+....+.....+.......+......+.........+...+.....+............+.+.....+...+......+...
....+..+...+......+.+...+..+.+........+.........+++++
..+........++++++++++++++++++++++++++++++++++++++++++++++*.+.............+.....+...+....+........+...+..........+.....
.+........+...+...+.+.....+...+.+..............+......+...+...........+..........+.....+.......+...................+
+.....+++++
-----
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:GH
State or Province Name (full name) [Some-State]:Accra
Locality Name (eg, city) []:Accra
Organization Name (eg, company) [Internet Widgits Pty Ltd]:LELCA COMPANY LIMITED
Organizational Unit Name (eg, section) []:Information, Technology
Common Name (e.g. server FQDN or YOUR name) []:LELCA server
Email Address []:leslieniiadjetey2000@gmail.com
```

b. Create a Python script named https_server.py that uses the generated certificate and key to run a basic HTTPS server on port 4443.

```
┌──(bones㉿vbox)-[~/Desktop]
└─$ touch pemscript.py

┌──(bones㉿vbox)-[~/Desktop]
└─$ nano pemscript.py

┌──(bones㉿vbox)-[~/Desktop]
└─$ cat pemscript.py
#!/usr/bin/env python3
"""
HTTPS Server Demonstration
This script creates a basic HTTPS server using SSL/TLS encryption
"""

import http.server
import ssl
import socketserver
import os
from datetime import datetime

class CustomHTTPRequestHandler(http.server.SimpleHTTPRequestHandler):
    """Custom HTTP request handler with enhanced logging and content"""

    def do_GET(self):
        """Handle GET requests with custom content"""
        if self.path == '/' or self.path == '/index.html':
            self.send_response(200)
            self.send_header('Content-type', 'text/html')
            self.send_header('X-Custom-Header', 'HTTPS-Demo-Server')
            self.end_headers()

            # Generate HTML response with encryption information
            html_content = f"""
            <!DOCTYPE html>
            <html lang="en">
            <head>
                <meta charset="UTF-8">
                <meta name="viewport" content="width=device-width, initial-scale=1.0">
                <title>HTTPS Encryption Demo</title>
                <style>
                    body {{
                        font-family: Arial, sans-serif;
                        max-width: 800px;
                        margin: 0 auto;
                        padding: 20px;
                        background-color: #f0f8ff;
                    }}
                    .header {{
                        background: linear-gradient(135deg, #667eea 0%, #764ba2 100%);
                        color: white;
                        padding: 20px;
                        border-radius: 10px;
                        text-align: center;
                        margin-bottom: 20px;
                    }}
                    .info-box {{
                        background: white;
                        padding: 15px;
                        border-radius: 8px;
                        margin: 10px 0;
                        border-left: 4px solid #667eea;
                        box-shadow: 0 2px 5px rgba(0,0,0,0.1);
```

c. Run the server and access https://127.0.0.1:4443 in your browser to verify secure communication.

Certificate

LELCA server

Subject Name

Country	GH
State/Province	Accra
Locality	Accra
Organization	LELCA COMPANY LIMITED
Organizational Unit	Information, Technology
Common Name	LELCA server
Email Address	leslieniiadjetey2000@gmail.com

Issuer Name

Country	GH
State/Province	Accra
Locality	Accra
Organization	LELCA COMPANY LIMITED
Organizational Unit	Information, Technology
Common Name	LELCA server
Email Address	leslieniiadjetey2000@gmail.com

Validity

Not Before	Sun, 20 Jul 2025 17:36:01 GMT
Not After	Mon, 20 Jul 2026 17:36:01 GMT

Public Key Info

Algorithm	RSA
Key Size	4096
Exponent	65537
Modulus	D0:27:A4:9D:B9:10:7D:8D:C3:2A:04:4F:68:DC:2D:98:F5:E6:4B:D4:B1:96:0F:...

Miscellaneous

Serial Number	4B:24:F2:C9:EE:9F:7D:0F:AD:57:16:FB:1A:B3:97:DC:03:04:11:71
Signature Algorithm	SHA-256 with RSA Encryption
Version	3
Download	PEM (cert) PEM (chain)

Fingerprints

SHA-256	31:44:BF:A6:0C:43:5A:C8:D3:12:7D:33:A6:88:40:A1:08:29:BD:B2:B1:7A:12:...
SHA-1	CD:CB:E8:26:67:2E:E1:A6:6A:C2:F2:78:BD:54:4D:E0:0A:66:CC:9F